

CyberEval Framework

Comprehensive Methodology & Implementation Guide

An evidence-driven framework for evaluating AI-generated cybersecurity analysis

1. Vision & Overview

Artificial Intelligence is an integral part of modern cybersecurity. However, convincing AI-generated responses are not necessarily trustworthy. Traditional evaluation methods focus on whether a model's final answer is "correct." CyberEval focuses on something different: **whether the conclusion was earned through evidence-based reasoning.**

"A correct answer without defensible reasoning is not a trustworthy answer. Evidence earns conclusions. Confidence reflects evidence. Risk reflects uncertainty."

Core Principles

- **Evidence Before Conclusions:** Conclusions must emerge from facts, not shape them.
- **Reasoning Must Be Explainable:** The logical path must be traceable.
- **Confidence Must Reflect Uncertainty:** Missing information reduces confidence.
- **Business Risk Matters:** Technical errors have operational and executive consequences.
- **Human Judgment Remains Essential:** CyberEval supports—not replaces—human reviewers.

2. Evaluation Methodology & Pipeline

CyberEval transforms raw AI output into structured intelligence through a sequential, multi-stage pipeline. Every stage has a single responsibility, and evidence flows forward immutably.

The 10-Stage Evaluation Lifecycle

Stage	Process	Objective
1. Input Processing	Ingest incident timeline, SIEM alerts, and AI response.	Establish the baseline context.
2. Evidence Extraction	Isolate factual observations independently.	Separate facts from AI narrative.
3. Evidence Classification	Assign reliability tiers to evidence items.	Distinguish direct proof from context.
4. Evidence Weighting	Prioritize evidence based on directness and reliability.	Prevent weak indicators from dominating.
5. Reasoning Evaluation	Check logical flow, assumptions, and consistency.	Ensure conclusions logically follow evidence.
6. Confidence Calibration	Compare stated certainty against available evidence.	Align confidence with reality.
7. Hallucination Detection	Identify reasoning failures (e.g., anchoring bias).	Explain why an AI response failed.
8. Risk Assessment	Evaluate Technical, Operational, and Business risks.	Measure operational consequence.
9. Executive Readiness	Check if the report is actionable and uncertainty is clear.	Prepare for stakeholder communication.
10. Final Report	Generate the overall structured assessment.	Deliver the final evaluation.

3. Evidence & Reasoning

Every conclusion depends on the quality of the supporting evidence. CyberEval evaluates evidence before reasoning.

Evidence Classification (Tiers)

- **Tier 1 — Direct Evidence:** Independently confirms an event (e.g., dumped credentials, active malware). Highest value.
- **Tier 2 — Supporting Evidence:** Strengthens a conclusion but requires correlation (e.g., PowerShell launched, Defender disabled).
- **Tier 3 — Contextual Evidence:** Provides context without proving events (e.g., Threat Intel, VirusTotal scores).
- **Tier 4 — Unknowns:** Unanswered questions (e.g., "Was data stolen?"). Unknowns are *not* evidence; they reduce confidence.

Reasoning Quality

An AI model may produce a correct answer through flawed logic. The framework evaluates reasoning across six components: *Observation Quality*, *Evidence Correlation*, *Inference Quality*, *Contradiction Analysis*, *Unknown Identification*, and *Final Assessment*.

Common Reasoning Failures

Unsupported Assumptions: Drawing conclusions without supporting data.

False Causality: Assuming one event caused another without proof.

Premature Closure: Concluding an investigation before sufficient facts exist.

4. Hallucinations & Confidence Calibration

In CyberEval, a hallucination is not just a fabricated fact; it is *any conclusion, recommendation, or attribution not sufficiently supported by evidence*.

Hallucination Taxonomy

Category	Definition
Unsupported Certainty	Presenting speculation as confirmed fact.
Anchoring Bias	Allowing a single weak observation to dominate reasoning.
Confirmation Bias	Selecting evidence to support a theory while ignoring contradictions.
Scope Creep	Extending conclusions beyond available evidence.
Unsupported Attribution	Attributing activity to an actor without sufficient IOCs.

Confidence Calibration

Confidence should communicate uncertainty, not optimism. It increases only with solid evidence and decreases when faced with unknowns or contradictions.

- **Low Confidence:** Limited evidence, significant unknowns, multiple assumptions.
- **Medium Confidence:** Supporting indicators exist, but investigation is ongoing.
- **High Confidence:** Strong direct evidence, few unknowns, consistent reasoning.
- **Very High Confidence:** Multiple independent sources, complete investigation (used sparingly).

5. Risk Assessment & Executive Reporting

A technically correct response can introduce risk through overconfidence or poor prioritization. CyberEval assesses risk based on the operational consequence of trusting the AI output.

Risk Dimensions

- **Technical Risk:** Incorrect mitigation mapping, malware classification, etc.
- **Operational Risk:** Delayed containment, incorrect prioritization.
- **Business Risk:** Underestimating credential compromise, business continuity threats.
- **Executive Risk:** Misleading CISOs or strategic decision-makers.

Executive Reporting Methodology

Technical details must be translated into decision-support documentation. Reports must:

1. Communicate decisions, not raw data.
2. Preserve technical accuracy without distortion.
3. Explain uncertainty and clearly document unknowns.
4. Separate observed facts from recommended actions.
5. Maintain traceability back to the evidence.

6. Implementation Guide & Data Model

CyberEval is designed as a modular, framework-independent backend system capable of connecting with multiple LLM vendors.

Data Model & Traceability

The system relies on structured, immutable objects (JSON). Every entity holds a globally unique identifier to maintain absolute traceability.

- **Incident Object:** Represents one investigation.
- **Evidence Object:** Immutable extraction of facts.
- **Claim Object:** Assertions extracted from the AI response.
- **Reasoning / Confidence / Risk Objects:** Discrete evaluation metrics tied to evidence.

Implementation Principles

Implementation should occur in phases: Base Data Layer → Evidence Engine → Reasoning Engine → Confidence Engine → Risk Engine → Reporting. Engines must communicate strictly via APIs and standardized JSON schemas without modifying each other's internal state.

Conclusion: *CyberEval ensures AI acts not as a black box of answers, but as a transparent, auditable, and operationally safe assistant for modern security teams.*